Launch checklist

Real App Club · The Ship Kit v1.0.13
Print this page or use the PDF. Check boxes only when true for your app.
This kit is a checklist and audit aid. It is not a security guarantee, penetration test, or legal advice. You are responsible for your app, your keys, and your launch.

1. Secrets

( ) No .env committed to git

( ) .env.example lists keys with fake or empty values only

( ) No sk_live / sk_test / service_role keys in client code

( ) Production secrets live in the host env (Vercel, Netlify, etc.)

2. Auth

( ) Private pages check the session on the server (not only in React state)

( ) Sign-out clears the session

( ) Auth redirect URLs include your production domain

3. Supabase

( ) Every public-schema user-data table has RLS enabled (always a Critical gap if missing; treat as Data API exposed unless proven otherwise; empty or missing GRANT rows in SQL are not proof it is private; proof means non-exposed schema or user-confirmed dashboard API settings only)

( ) Policies use auth.uid() (or equal) for ownership

( ) No user-writable entitlement columns on own row (role, plan, tier, credits, balance, is_admin, is_pro) without server-side lock-down (Critical if they grant admin/paid access)

( ) No SELECT USING (true) (or equivalent) on per-user private tables (tables where each row belongs to one user: personal entries, private messages, health, location or billing records, contact details) (Critical)

( ) Service role key used only on a trusted server

4. Stripe (skip if you have no payments)

( ) Webhook uses constructEvent with the raw body and signing secret

( ) Charge amount comes from server-side prices or Stripe Price IDs you control (never trust a client-sent price, amount, currency, quantity-based total, or Price ID choice) (Critical)

( ) Access is granted from verified webhook or server-side session retrieve

( ) Test mode purchase + webhook delivery succeeded once

( ) Live mode webhook endpoint added before real charges

5. App quality

( ) Error page does not show stack traces to users

( ) Basic logging or error tracker is on in production

( ) Title and meta description set

( ) Privacy policy and terms linked from the site

6. Go live

( ) Production build succeeds locally or on CI

( ) Custom domain HTTPS works

( ) Ran Ship Kit security-audit and fixed Critical items

( ) Ran Ship Kit pre-launch and got GO (or accepted listed risks in writing)

After launch (first 24 hours)

( ) Watch Stripe dashboard for failed webhooks

( ) Watch Supabase auth and API logs

( ) Click sign-up, sign-in, pay (if any), and a private page yourself

Need the free taste? Ship Kit Lite on GitHub points here for the full kit.